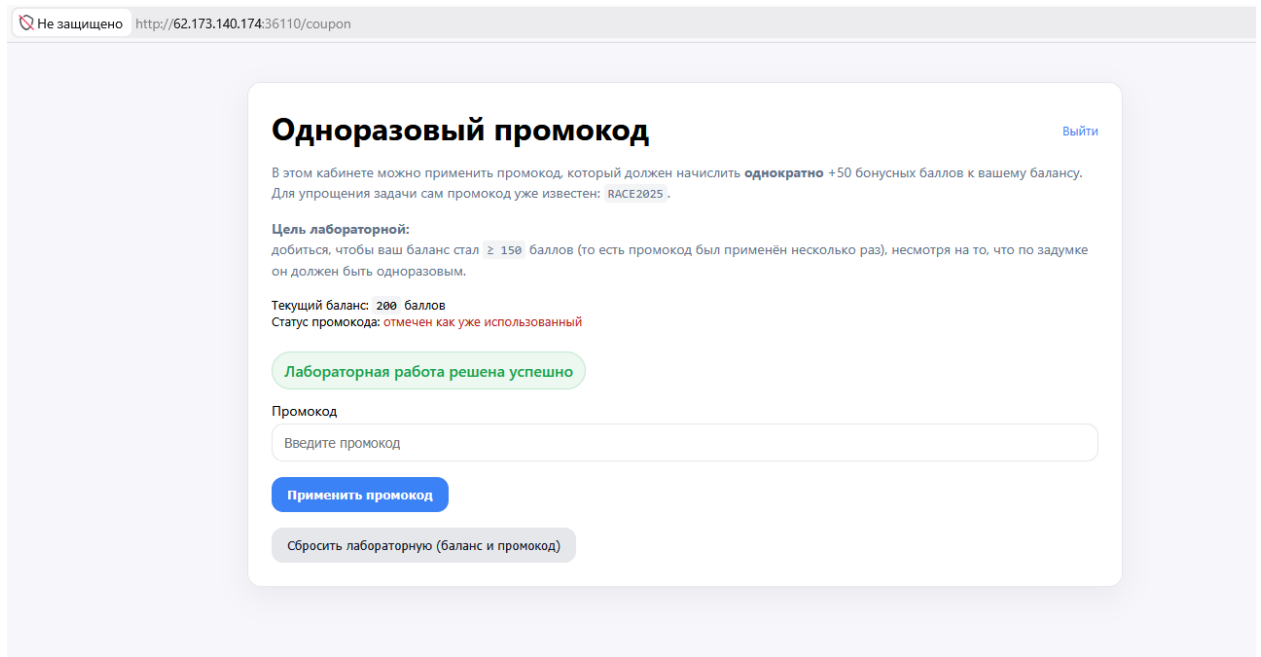


Задание 15. Race condition

URL: <http://62.173.140.174:36110/>

1. Скриншот результатов



2. Шаги воспроизведения

1. Открыл страницу стенда в Burp Suite.
2. Ввел промокод RACE2026. Нажал на кнопку “отправить”.
3. Перехватил запрос с помощью Burp Suite.
4. Скопировал запрос в Repeater.
5. Скопировал запросы, доведя их число до 4. Объединил их в группу.
6. Отправил группу запроса в параллельном режиме.
7. В ответах по каждому запросу убедился, что есть уязвимость типа Race Condition. Каждый ответ с одним и тем же запросом прибавил число баллов. Итоговая сумма получилась равной 200.

3. Используемый способ атаки

- Использовался инструмент Burp Suite Community Edition. Запросы были отправлены параллельно
- Тело запроса и заголовки никак не модифицировались и совпали с перехваченным запросом при нажатии на кнопку “отправить”

- Число запросов: 4

4. Скриншоты подтверждения

The screenshot shows the Burp Suite interface with the following components:

- Request Tab:** Displays the raw HTTP request, including headers like 'Host: 62.173.140.174:36110' and 'Content-Type: application/x-www-form-urlencoded'. The body contains a 'code' parameter with the value 'RACE2025'.
- Response Tab:** Shows the server's response, which includes a confirmation message: 'Лабораторная работа решена успешно' (Laboratory work completed successfully). It also displays the current balance as 200 points and the status of the promo code as 'отмечен как уже использованный' (marked as already used).
- Inspector Tab:** Provides details about the request, including the method (POST), path (/coupon), and the request body parameters (code: RACE2025).

5. Краткий разбор риска (2–4 строки)

Данная уязвимость позволяет обходить бизнес-логику ограничения одноразовых действий. В реальных системах это приводит к финансовым потерям (неограниченное применение скидок), несанкционированному пополнению баланса или манипуляции складскими запасами.

6. Как бы вы починили

- Особо чувствительные операции производить в однопоточном режиме (блокировка).

```
lock = threading.Lock()
with lock:
    ...
```

- Обеспечить атомарность операции при проверке и применении промокода. Например, через пессимистичные блокировки: `SELECT FOR UPDATE` Либо через атомарный SQL-запрос `UPDATE` с условием проверки статуса купона.
- Использовать ограничения на уровне БД. Уникальные индексы (чтобы нельзя было создать одинаковый объект дважды)